

Stripe processes payment data on your behalf — making it one of your most important data processors under GDPR. This guide covers everything you need to do to stay compliant when using Stripe.

Understanding Stripe's GDPR Role

Concept	What it means for you
Stripe as Data Processor	When your customers pay, Stripe processes their card data on your behalf. You are the Data Controller.
Stripe as Data Controller	For some data (e.g. fraud prevention, Stripe's own analytics), Stripe acts as an independent Data Controller.
Your Responsibility	You must inform customers that Stripe processes their payment data. This should be stated in your privacy policy.

Step 1 · Accept Stripe's Data Processing Agreement

- Log in to your Stripe dashboard at dashboard.stripe.com
- Go to Settings → Compliance → GDPR
- Click Accept on Stripe's Data Processing Agreement
- Screenshot or download the confirmation — keep it for your records
- Stripe's DPA covers all EU/EEA data processing and includes Standard Contractual Clauses

Step 2 · Update Your Privacy Policy

- The GDRock Privacy Policy template already includes Stripe in the processors list
- Ensure your policy states: payment data is processed by Stripe Payments Europe Ltd
- Include Stripe's privacy policy link: stripe.com/privacy
- State that no full card numbers are stored on your servers — only Stripe stores these
- Confirm that Stripe is PCI-DSS compliant (Level 1 — the highest level)

Step 3 · Configure Stripe for GDPR Compliance

- Enable Radar (fraud detection) — this is legitimate interests, document it in your RoPA
- Review which Stripe data you access via the API — only request what you need
- Set up webhook endpoints securely — use HTTPS only
- Enable 2FA on your Stripe account — go to Settings → Security
- Review which team members have Stripe access — remove anyone who does not need it
- Use Stripe's restricted API keys for different parts of your system

Step 4 · Handle Customer Data Requests Involving Stripe

- For data access requests: export customer data from Stripe → Customers → Export
- For erasure requests: Stripe can redact customer data — go to Customers → [customer] → Redact
- Note: Stripe must retain some transaction data for legal/financial reasons (7 years)
- This retention is covered under legal obligation — document it in your Retention Table
- For portability requests: export transactions as CSV from Stripe dashboard

Step 5 · International Transfers

- Stripe's EU operations are handled by Stripe Payments Europe Ltd (Ireland)
- Data may be transferred to the US — covered by Stripe's Standard Contractual Clauses
- You do not need separate transfer agreements — Stripe's DPA covers this
- Document this transfer in your Record of Processing Activities (RoPA)

Step 6 · Breach Response with Stripe

- If you suspect a breach involving Stripe data: contact Stripe immediately
- Stripe support: support.stripe.com · Security issues: security@stripe.com
- Stripe will notify you of any breach on their infrastructure within 72 hours
- You must assess whether the breach triggers your own notification obligations
- Use the GDRock Breach Response Pack to manage your regulatory notification

Stripe GDPR Compliance Checklist

■ Stripe Data Processing Agreement accepted in dashboard	■ Done
■ Privacy policy mentions Stripe as payment data processor	■ Done
■ No full card numbers stored on your servers	■ Done
■ 2FA enabled on Stripe account	■ Done
■ Access controls reviewed — minimal team access	■ Done
■ Restricted API keys used where possible	■ Done
■ Stripe transfer mechanism documented in RoPA	■ Done
■ Process for Stripe data erasure requests documented	■ Done
■ Stripe security contact saved: security@stripe.com	■ Done
■ Webhook endpoints secured with HTTPS	■ Done